

# Security+ 5.6 · User Training

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 5.6 — User Training (4:31)** · [Vídeo no YouTube ↗](#)

---

**Resumo da Aula:** Quem: employees, management, third-parties/fornecedor; como: presencial/online/email/CTF; frequência: na contratação + periódico + após incidente; customização por função (executivo: whaling; financeiro: BEC).

## Highlights que a prova cobra

---

- Treina POR FUNÇÃO: executivo recebe whaling; financeiro BEC
- Frequência: contratação + periódico + após incidente

## Dicas de prova & Cenários Típicos

---

- 'training customized based on job role'=role-based awareness training

**Cenário clássico de exame:** 'executivo recebe o treinamento específico de whaling'=customização por papel.

## 🔔 Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Seção 5.6)

**Por que este aprofundamento é cobrado no exame?** O vídeo do Professor Messer (User Training) resume os conceitos de forma ágil. Contudo, a banca examinadora oficial da CompTIA (SY0-701) exige raciocínio prático de engenharia de segurança, diferenciação entre protocolos concorrentes e aplicação em cenários corporativos reais. Entenda os conceitos complementares fundamentais:

- **Estratégias de Tratamento de Risco:**
  - **Mitigação/Redução:** aplicar controles técnicos ou administrativos para diminuir probabilidade ou impacto (ex: instalar EDR).
  - **Transferência/Compartilhamento:** repassar o impacto financeiro para um terceiro (ex: contratar seguro cibernético ou terceirizar para um MSSP).
  - **Aceitação:** reconhecer o risco quando o custo do controle supera o valor do ativo (exige aprovação formal da alta liderança).
  - **Evitação:** cancelar ou não iniciar a atividade arriscada (ex: descontinuar um serviço legado inseguro).
- **Métricas de Risco e Análise Quantitativa:**
  - **SLE (Single Loss Expectancy):** perda financeira estimada para uma única ocorrência do incidente ( $\text{Asset Value} \times \text{Exposure Factor}$ ).
  - **ARO (Annualized Rate of Occurrence):** frequência anual estimada do evento.
  - **ALE (Annualized Loss Expectancy):** custo anualizado total do risco:  $\text{ALE} = \text{SLE} \times \text{ARO}$ .
- **Métricas de Continuidade de Negócios (BCP / DRP):**
  - **RTO (Recovery Time Objective):** tempo máximo tolerável que o sistema pode ficar inoperante após um desastre.
  - **RPO (Recovery Point Objective):** volume máximo de dados que a organização tolera perder, medido em tempo (ex: se o backup é diário, o RPO é de até 24 horas de transações perdidas).
  - **MTBF (Mean Time Between Failures):** tempo médio em que um equipamento opera sem falhas.
  - **MTTR (Mean Time to Repair):** tempo médio necessário para consertar ou substituir um componente com defeito.

### ⚠️ Armadilhas e Pegadinhas Clássicas da Banca:

- Se a questão disser 'contratar apólice de seguro contra ataques cibernéticos' = **Transferência de Risco** (nunca mitigação).
- RPO define a frequência dos backups; RTO define a velocidade da infraestrutura de restauração e failover.

## ✓ Perguntas de treino comentadas (10 questões)

---

Gabarito com resolução passo a passo e análise dos distratores no fim. Tente responder antes de olhar.

**1. Golpista liga se passando por suporte de TI e cria urgência pra tu dar a senha. O princípio de engenharia social explorado é:**

- A)** Escassez
- B)** Autoridade + urgência
- C)** Prova social
- D)** Reciprocidade

**2. Um funcionário recebe ligação de alguém se passando por suporte técnico solicitando senha para 'atualização do sistema'. Que técnica é essa?**

- A)** Vishing
- B)** Pretexting
- C)** Baiting
- D)** Tailgating

**3. Cenário corporativo (User Training):** Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.6), um analista avalia o seguinte requisito técnico: 'Treina POR FUNÇÃO: executivo recebe whaling; financeiro BEC'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Treina POR FUNÇÃO: executivo recebe whaling; financeiro BEC...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

**4. Cenário corporativo (User Training):** Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.6), um analista avalia o seguinte requisito técnico: 'Frequência: contratação + periódico + após incidente'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Frequência: contratação + periódico + após incidente...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

**5. Cenário corporativo (User Training):** Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.6), um analista avalia o seguinte requisito técnico: 'training customized based on job role'=role-based awareness training'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'training customized based on job role'=role-based awareness training...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

**6. Cenário corporativo (User Training):** Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.6), um analista avalia o seguinte requisito técnico: 'executivo recebe o treinamento específico de whaling'=customização por papel.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'executivo recebe o treinamento específico de whaling'=customização por pap...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

**7. Cenário corporativo (User Training):** Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.6), um analista avalia o seguinte requisito técnico: 'Treina POR FUNÇÃO: executivo recebe whaling; financeiro BEC'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Treina POR FUNÇÃO: executivo recebe whaling; financeiro BEC...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

**8. Cenário corporativo (User Training):** Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.6), um analista avalia o seguinte requisito técnico: 'Frequência: contratação + periódico + após incidente'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Frequência: contratação + periódico + após incidente...

**9. Cenário corporativo (User Training):** Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.6), um analista avalia o seguinte requisito técnico: '"training customized based on job role'=role-based awareness training'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'training customized based on job role'=role-based awareness training...

**10. Cenário corporativo (User Training):** Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.6), um analista avalia o seguinte requisito técnico: "executivo recebe o treinamento específico de whaling'=customização por papel.". Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'executivo recebe o treinamento específico de whaling'=customização por pap...

## GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

### 1) B — Autoridade + urgência.

✓ **Por que está certa:** Fingir autoridade (TI) + pressa desliga o pensamento crítico. É o combo clássico da engenharia social — teu lado investigador reconhece o roteiro.

#### ✗ **Por que as outras estão erradas:**

- *Escassez:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Prova social:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Reciprocidade:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

### 2) A — Vishing.

✓ **Por que está certa:** Vishing = phishing por VOZ/telefone (a 'ligação' é a chave). O golpista finge ser o suporte pra extrair a senha. (Pretexting é a técnica do cenário inventado, muitas vezes usada JUNTO com o vishing.)

#### ✗ **Por que as outras estão erradas:**

- *Pretexting:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Baiting:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Tailgating:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

### 3) C — Implementar a solução correspondente: Treina POR FUNÇÃO: executivo recebe whaling; financeiro BEC....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.6 (User Training): Treina POR FUNÇÃO: executivo recebe whaling; financeiro BEC.

#### ✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

### 4) B — Implementar a solução correspondente: Frequência: contratação + periódico + após incidente....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.6 (User Training): Frequência: contratação + periódico + após incidente.

#### ✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para

detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).

- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

**5) B — Implementar a solução correspondente: 'training customized based on job role'=role-based awareness training....**

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.6 (User Training): 'training customized based on job role'=role-based awareness training.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

**6) A — Implementar a solução correspondente: 'executivo recebe o treinamento específico de whaling'=customização por pap....**

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.6 (User Training): 'executivo recebe o treinamento específico de whaling'=customização por papel..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

**7) A — Implementar a solução correspondente: Treina POR FUNÇÃO: executivo recebe whaling; financeiro BEC....**

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.6 (User Training): Treina POR FUNÇÃO: executivo recebe whaling; financeiro BEC.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).

- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

**8) D — Implementar a solução correspondente: Frequência: contratação + periódico + após incidente....**

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.6 (User Training): Frequência: contratação + periódico + após incidente.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

**9) D — Implementar a solução correspondente: 'training customized based on job role'=role-based awareness training....**

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.6 (User Training): 'training customized based on job role'=role-based awareness training.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

**10) D — Implementar a solução correspondente: 'executivo recebe o treinamento específico de whaling'=customização por pap....**

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.6 (User Training): 'executivo recebe o treinamento específico de whaling'=customização por papel..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são

controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.

- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.